MITTRE ATT&CK Powered Analysis

OBJECTIVES

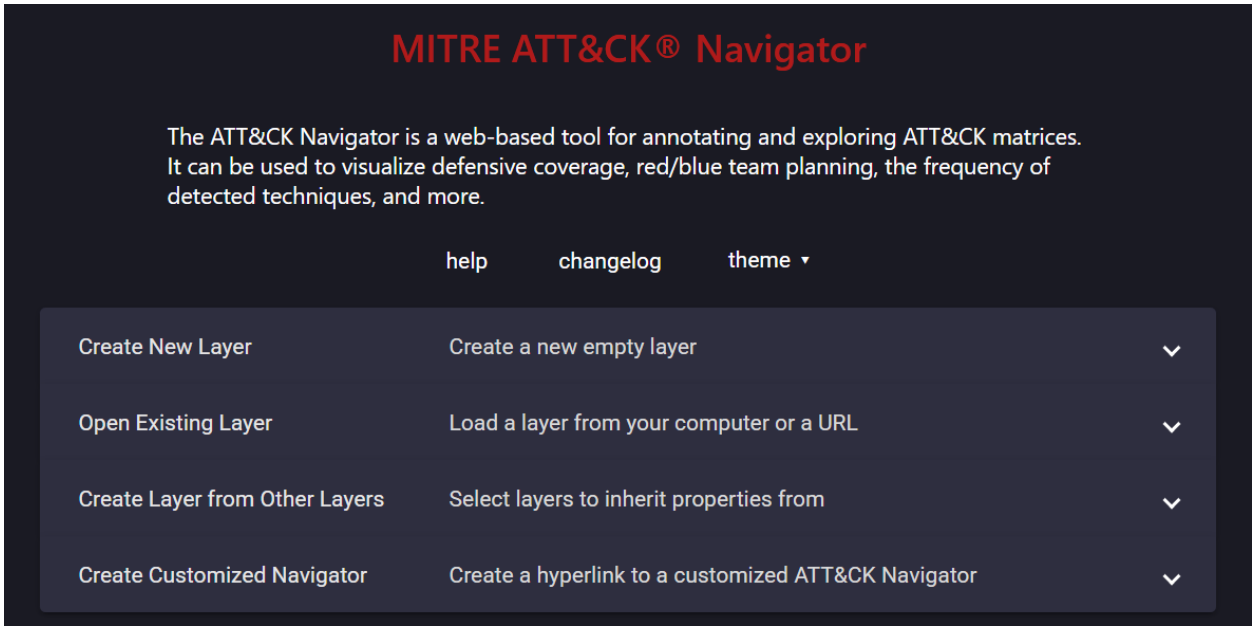
The objective of this lab is to work with MITRE ATT&CK Navigator and demonstrate how it can be used as part of a CTI investigation; investigating ATP29 group, the SUNBURST malware and mitigating their techniques by mapping the NIST 800-53 controls.

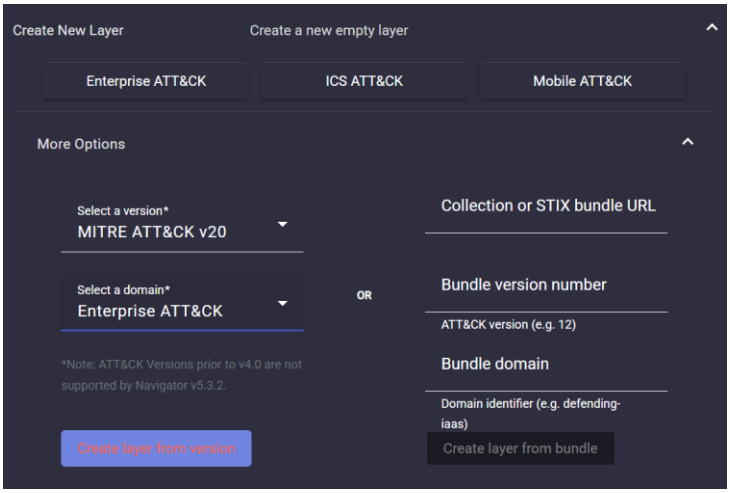
By the end of this analysis, I could

- Navigate and explore the MITRE ATT&CK Enterprise matrix.
- Understand the relationship between tactics, techniques and sub-techniques.
- Profile an Advanced Persistent Threat (APT) group using MITRE ATT&CK.
- Analyze malware behavior and identify its associated ATT&CK techniques.
- Identify defensive measures to mitigate observed attack techniques.

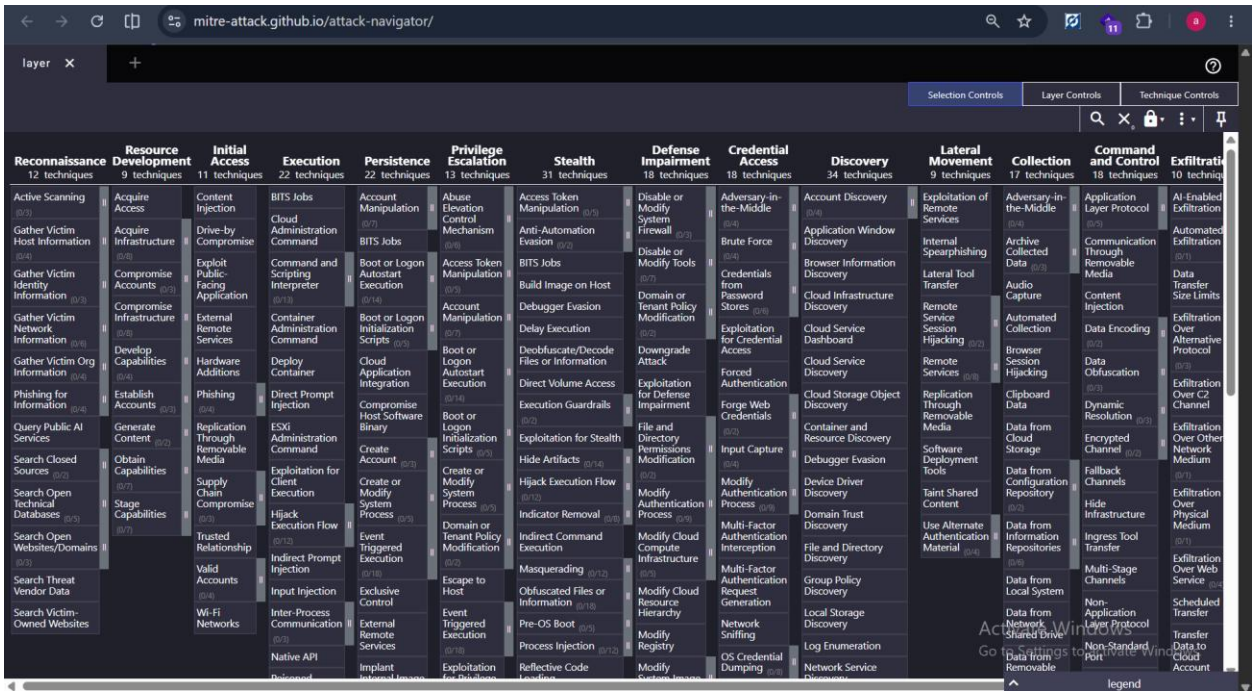
PART I – EXPLORING ATT&CK NAVIGATOR

MITTRE ATT&CK's Navigator is a web based app that makes it easy to work eith ATT&CK matrices: https://mitre-attack.github.io/attack-navigator

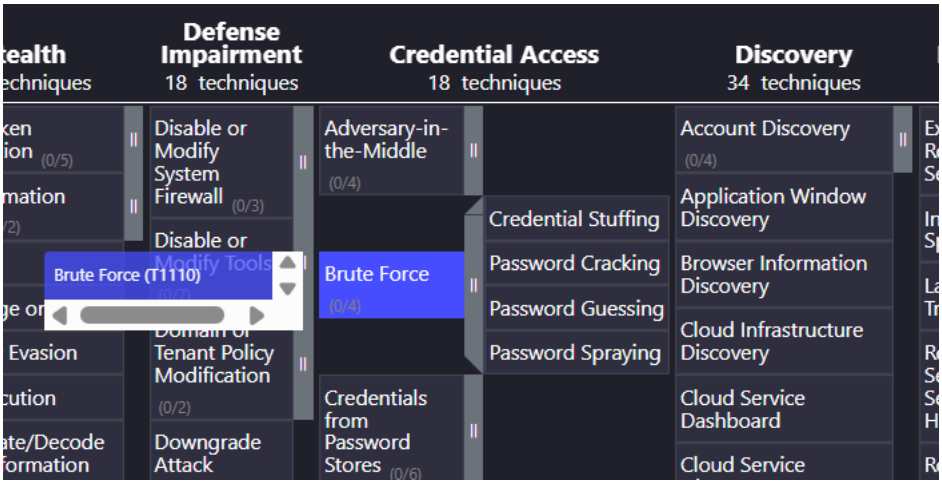




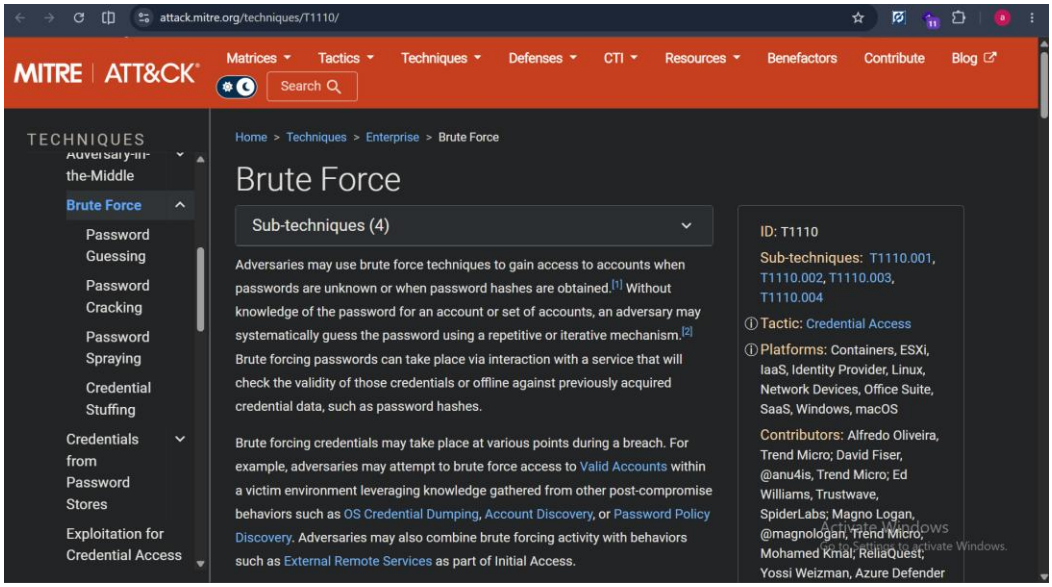
This is the Tactic and technique matrix:



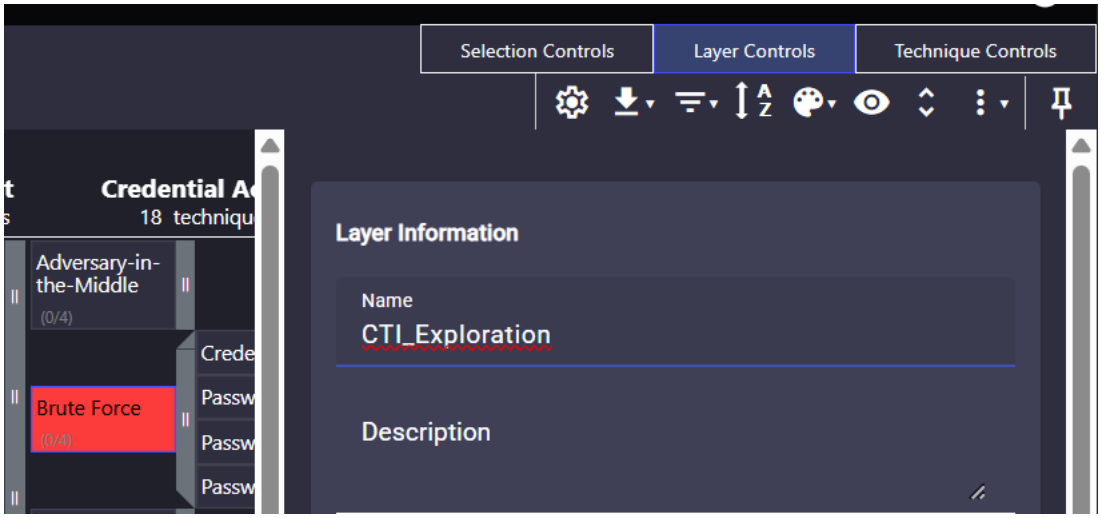
For example the credential access tactic has 18 techniques, notably the Brute Force technique with ID T1110:



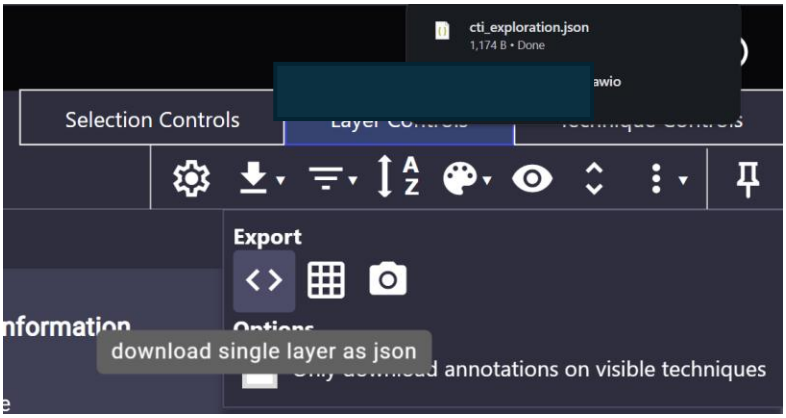
We can see more details about the Brute Force technique, such as its subtechniques, procedures, detection methods and mitigations:



We can also set a unique bg color and ads a name and description to the layer



As well as export and save it as JSON:



What is the difference between a tactic, a technique and a sub-technique?

A tactic is the attackers' end objective, a technique is the method used to achieve it and the sub-techniques are the variations of a technique.

What does a technique represent from the attacker's perspective?

A technique is the method used to achieve their final malicious objective

What information can an analyst obtain from the description and mitigation sections of a technique?

Analysts can understand when and how an attack happens and knows how to detect it and defend against it.

What is the purpose of creating and customizing layers in ATT&CK Navigator?

This makes the mittre att&ck matrix more specific to our own environment rather then being generic.

PART II – CTI INVESTIGATION: APT GROUP PROFILING

Investigation Scenario:

Our organization has received intelligence reports indicating that an advanced threat group may be targeting organizations in our sector.

The CTI team has been asked to investigate the group's behavior, understand its attack techniques and identify potential security weaknesses.

So I am assigned to **investigate APT29**, a threat group documented in MITRE ATT&CK: https://attack.mitre.org/groups/G0016/ and **to build a behavioral profile** of this adversary using the MITRE ATT&CK knowledge base and Navigator.

It is stated that this group is associated with the Russian intelligence and has multiple aliases such as StellarParticle, Dark Halo, and SolarStorm…

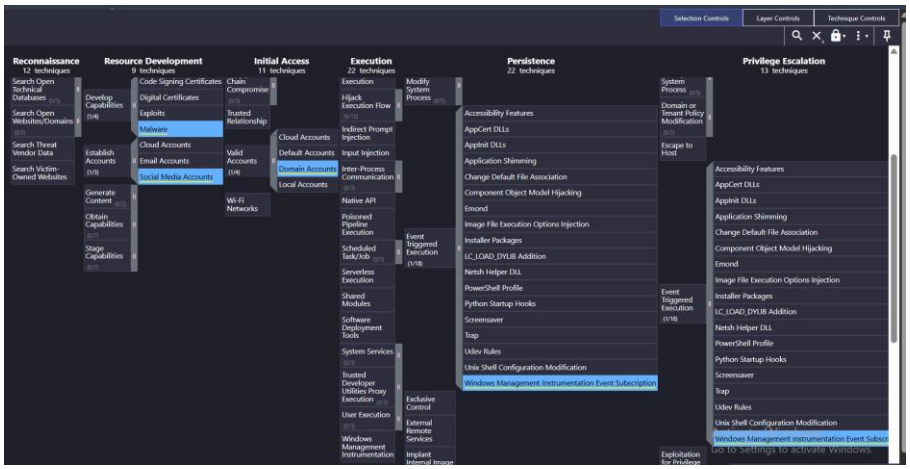
It also states that the APT29 group is linked with attack campaigns such as Operation Ghost and details the techniques used during the campaign; from registering domains and twitter accounts to appear legit to steganography and malware to exploit targets under the radar.

Techniques Used

ATT&CK® Navigator Layers

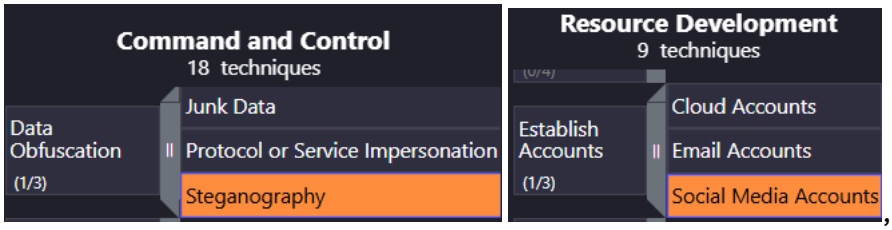
Domain	ID		Name	Use
Enterprise	T1583	.001	Acquire Infrastructure: Domains	For Operation Ghost, APT29 registered domains for use in C2 including some crafted to appear as existing legitimate domains.[1]
Enterprise	T1001	.002	Data Obfuscation: Steganography	During Operation Ghost, APT29 used steganography to hide the communications between the implants and their C&C servers.[1]
Enterprise	T1587	.001	Develop Capabilities: Malware	For Operation Ghost, APT29 used new strains of malware including FatDuke, MiniDuke, RegDuke, and PolyglotDuke.[1]
Enterprise	T1585	.001	Establish Accounts: Social Media Accounts	For Operation Ghost, APT29 registered Twitter accounts to host C2 nodes.[1]

And it's color coded ATT&CK layer helps in visualizing those techniques

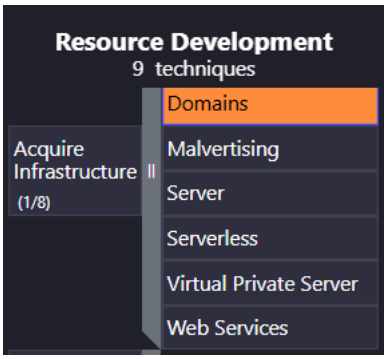


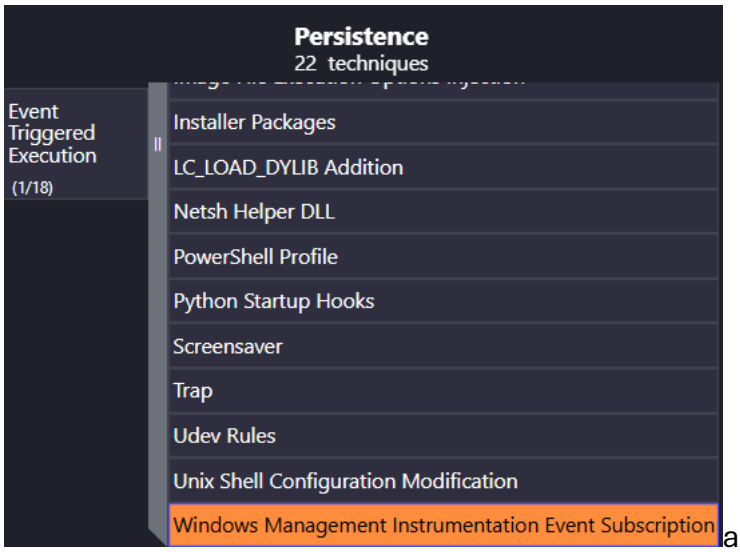
Let’s try to recreate the layer from scratch and compare it with the ATT&CK built-in layer fo the APT29 group:

For example:

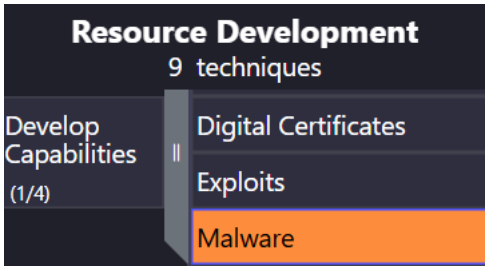


,

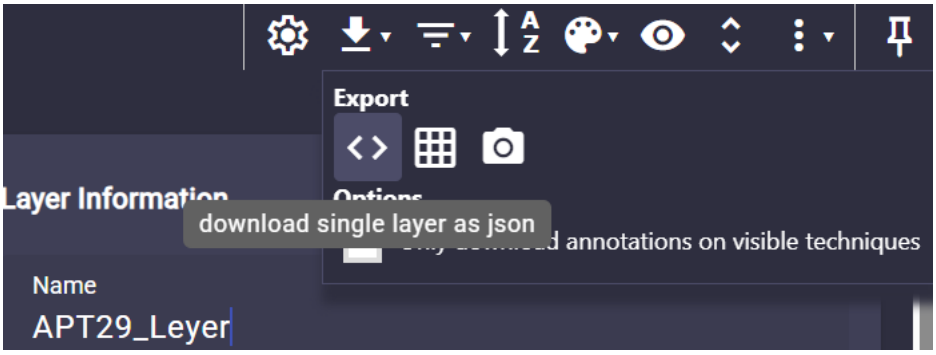




and



Like this, whe have created a layer that illustrates the malicious behavioral profile of the APT29 group, so let’s save it:



For the Behavioral analysis;

The tactics represented by the APT29 profile are Initial Access, Command and Control (C2), Defense Evasion, Persistence…

Selecting the most important techniques for understanding APT29's behavior, can be achieved by looking for bottlenecks in APT29's ATT&CK layer , which means, looking for the tactic that the apt29 group achieved using only one particular technique for example, that could mean they excel at it and will most likely keep try achieving the tactic using that technique.

For example to achieve *Initial access*, they have historically been consistent at only using Valid Accounts: Domain Acounts technique and subtechnique, which also appears to be used by the group to achieve multiple tactics.

Some concurrent techniques used by the group are WMI for privesc and persistence and steganography for stealth and C&C tactics

How can an organization use this behavioral profile to improve its threat detection capabilities?

To improve our organization's threat detection capabilities, we could set **detection rules** in our NIDS and HIDS and other detection systems, specific for the techniques related to this APT29 group that is currently targeting firms in our sector.

PART III – CTI INVESTIGATION: MALWARE ANALYSIS AND TECHNIQUE CORRELATION

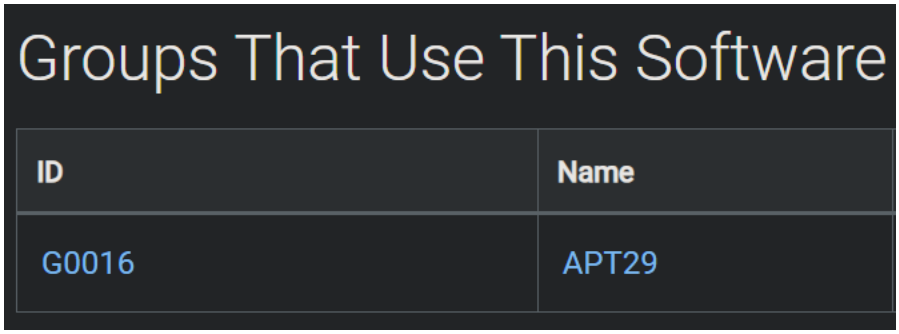
During investigation, I discovered references to SUNBURST, a malicious backdoor associated with the SolarWinds supply-chain compromise.

Let's investigate this malware, understand its behavior and compare its techniques with those associated with APT29.

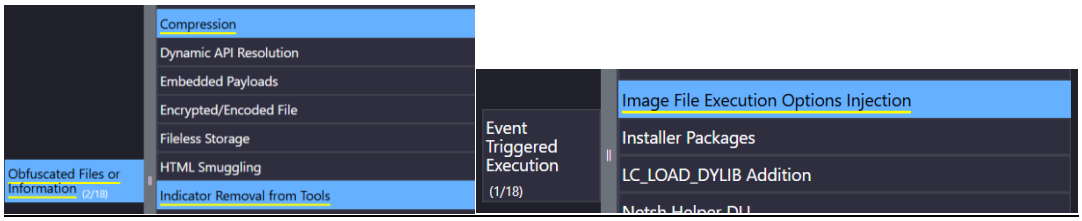
SUNBURST is a trojanized DLL designed to fit within the SolarWinds Orion software update framework. It was used by APT29 since at least February 2020. https://attack.mitre.org/software/S0559/

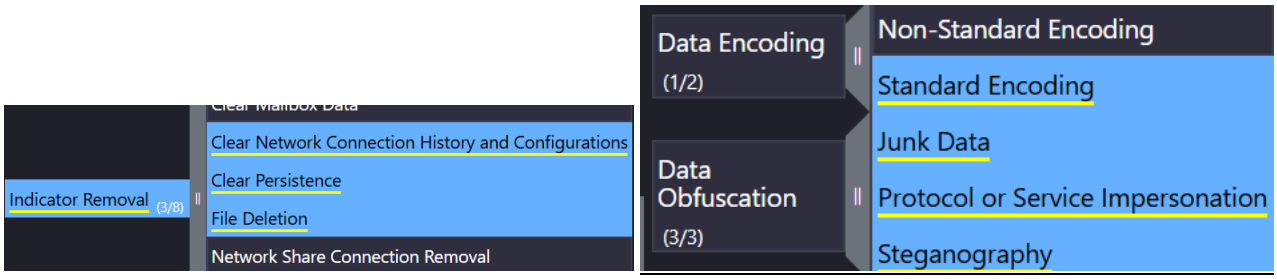
It used Application Layer Protocol techniques such as DNS subtechnique to communicate with C2, Encoding: Standard Encoding and Encrypted Channel: Symmetric Cryptography where It base64 encoded and encrypted data in C2 traffic. And for evasion it used Indicator Removal and many more.

This was indeed used by the APT29 group



Let's try to create and save a MITTRE ATT&CK Navigator Layer for SUNBURST using some techniques:





The main attack behaviors associated with SUNBURST?

- Supply Chain Compromise: Injected maliciously modified code (SolarWinds.Orion.Core.BusinessLayer.dll) into digitally signed software packages to appear legit.
- Sleep Periods: Remained dormant for days after installation before executing any behavior to evade detection.

An example of techniques that are common to both APT29 and SUNBURST?

- Code Signing and Supply Chain Subversion: used trusted software pipelines to distribute backdoors signed with legit certificates.
- Defense Evasion: bypass endpoint protection.

What can the correlation between an adversary group and its associated malware reveal about an attack campaign?

- This could help understand how malicious actors distribute the malware into the target environment, by correlating their entry points and the mawares initial evasion techniques for example.
- It also highlights the behaviors in common to understand the methodology and intent.

Can the use of SUNBURST alone be considered sufficient evidence to attribute an attack to APT29?

- No, despite APT29 and SUNBURST being linked, this doesn't mean it alone can be sufficient to determine it is the APT29 group.
  In fact other threat actors can deploy open-source malwares or infere the malware from its behavior to achieve similar goals.
  To determine the source for sure, more intel should be acquired and correlated.

PART IV – THREAT-INFORMED DEFENSE

Following the previous investigation, the organization wants to strengthen its security posture against the identified techniques.

As a CTI analyst, I need to translate adversary intelligence into actionable defensive recommendations.

The techniques that we will work on defending against will be: Supply Chain Compromise & Valid Accounts

Supply Chain Compromise

Sub-techniques (3)

ID	Name
T1195.001	Compromise Software Dependencies and Development Tools
T1195.002	Compromise Software Supply Chain
T1195.003	Compromise Hardware Supply Chain

Adversaries may manipulate products or product delivery mechanisms prior to receipt by a final consumer for the purpose of data or system compromise.

- ⇨ Mitigations:

ID	Mitigation	Description
M1013	Application Developer Guidance	Application developers should be cautious when selecting third-party libraries to integrate into their application. Additionally, where possible, developers should lock software dependencies to specific versions rather than pulling the latest version on build.[16]
M1046	Boot Integrity	Use secure methods to boot a system and verify the integrity of the operating system and loading mechanisms.
M1033	Limit Software Installation	Where possible, consider requiring developers to pull from internal repositories containing verified and approved packages rather than from external ones.[16]
M1051	Update Software	A patch management process should be implemented to check unused dependencies, unmaintained and/or previously vulnerable dependencies, unnecessary features, components, files, and documentation.

AND...

Valid Accounts

Sub-techniques (4)

ID	Name
T1078.001	Default Accounts
T1078.002	Domain Accounts
T1078.003	Local Accounts
T1078.004	Cloud Accounts

Adversaries may obtain and abuse credentials of existing accounts as a means of gaining Initial Access, Persistence, Privilege Escalation, or Defense Evasion. Compromised credentials may be used to bypass access controls placed on various resources on systems within the network and may even be used for persistent access to remote systems and externally available services, such as VPNs, Outlook Web Access, network devices, and remote desktop.[1]

⇨ Mitigations:

ID	Mitigation	Description
M1036	Account Use Policies	Use conditional access policies to block logins from non-compliant devices or from outside defined organization IP ranges.[105]
M1015	Active Directory Configuration	Disable legacy authentication, which does not support MFA, and require the use of modern authentication protocols instead.
M1013	Application Developer Guidance	Ensure that applications do not store sensitive data or credentials insecurely. (e.g. plaintext credentials in code, published credentials in repositories, or credentials in public cloud storage).
M1032	Multi-factor Authentication	Implement multi-factor authentication (MFA) across all account types, including default, local, domain, and cloud accounts, to prevent unauthorized access, even if credentials are compromised. MFA provides a critical layer of security by requiring multiple forms of verification beyond just a password. This measure significantly reduces the risk of adversaries abusing valid accounts to gain initial access, escalate privileges, maintain persistence, or evade defenses within your network.

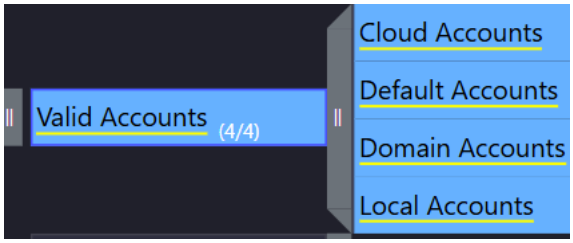
To map security behaviors to security controls, let's consider the NIST SP 800-53 Rev. 4 framework, particularly the control AC-2 – Account Management and use your MITRE ATT&CK Navigator to import a pre-built mapping layer and visualize whichATT&CK techniques align with this control.

https://raw.githubusercontent.com/center-for-threat-informed-defense/attack-control-framework-mappings/main/frameworks/attack_10_1/nist800_53_r4/layers/by_family/Access_Control/AC-2.json



This show every MITRE ATT&CK technique and sub-technique where NIST SP 800-53 AC-2 (Account Management) can help prevent.

For example we can see how it mitigates the Valid account technique since it is highlighted in the layer:



Organizations usually identify risks related to their context and thanks to mittre they can identify the related techniques that could make the risk a reality.

Now to mitigate them, organizations need to apply security controls, such as ones from standard frameworks like NIST's 800-53 and, using the mittre layer of the control, they can see the exact techniques that those controls defend against, thus providing a comprehensive defensive coverage without missing any technique or even sub-technique, which substantially improve security against the identified malicious attacks or groups.

END